Lab4-1 知情权审计汇报

Android 隐私检测系统 • 证据驱动的政策声明与多源观测一致性分析

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-05-25

目录

1. 汇报范围与目标
2. 系统与流水线
3. 实验设计
4. 实验结果
5. 总结与展望

本次汇报范围

- 课程/课题 **Lab4** 要求从「文本承诺」延伸到「技术可验证」：政策声明是否与真实采集、开关控制、副本导出一致。
- 早期方案以 **LLM 主导**判断为主；现实现以 **证据包 + 规则引擎 + 法律知识库**为主，因此本次实验中 LLM 仅保留在政策句级审计历史链路。
- 使用**多源观测证据链**：规则引擎判定 + 每条 verdict 可溯源（sources / provenance），非 LLM 黑盒结论。
- **数据批次** 10 App: 小红书、Keep、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康、微信。

知情权评价内容，与如何构建多源观测证据链

输入 declared_pii	政策文本 → 解析的 PII 类型列表（如手机号、位置、设备标识等）
输入 observed_pii	静态 APK + 动态取证 + oldsrc 历史 + 法律知识库合并的观测类型
处理	比对得到声明/观测矩阵，输出判定结果
输出	consistent / inconsistent_high_risk / declared_not_observed 等标签以及溯源信息
合规含义	声明与行为是否匹配;「高风险不一致」= 观测到但政策未充分声明

compare_engine 处理过程

compare_engine 规则（compare_engine.py）

```
for pii_type in all_types:
    if pii_type in declared and pii_type in observed:
        rule = rule_map.get(
            "declared and observed",
            defaults["declared and observed"],
        )
    elif pii_type not in declared and pii_type in observed:
        rule = rule_map.get(
            "not_declared and observed",
            defaults["not_declared and observed"],
        )
    else:
        rule = rule_map.get(
            "declared and not_observed",
            defaults["declared and not_observed"],
        )
    verdicts.append(
        {
            "pii_type": pii_type,
            "status": rule["verdict"],
            "risk_level": rule["risk_level"],
            "message": rule["message"],
            "evidence_fields": rule["evidence_fields"],
```

compare_engine 处理过程

规则引擎判定伪代码（decision_rules.yaml）

```
- when: "declared and observed"
  verdict: "consistent", risk_level: "low"
- when: "not_declared and observed"
  verdict: "inconsistent_high_risk", risk_level: "high"
- when: "declared and not_observed"
  verdict: "declared_not_observed", risk_level: "medium"
```

高风险不一致：有观测证据，但政策未充分声明。

- 政策未写全 / 写得不具体，但应用确实要求了政策之外的敏感信息。
- 政策声明了，但当前合并证据收集时，未加入到证据库。

中风险不一致：政策声明了，但当前合并证据未观测到。

- 证据验证路径功能受限或不完整。
- 应用使用了受限 API，但未在政策中声明。

kb_verdict_adjustments 处理过程

apply_kb_verdict_adjustments（kb_verdict.py）

```
for row in verdicts:
    pii_type = row.get("pii_type", "")
    in_declared = pii_type in declared
    in_technical = pii_type in technical
    in_kb = pii_type in kb_types or pii_type in kb_supported
    kb_only = in_kb and not in_technical
    new_row = dict(row)
    if (
        in_declared and not in_technical
        and (in_kb or pii_type in kb_supported
             or pii_type in declared_support)
        and row.get("status") == "declared_not_observed"
    ):
        new_row.update({
            "status": kb_confirm["verdict"],
            "risk_level": kb_confirm["risk_level"],
            "verdict_basis": "knowledge_base",
            "kb_influenced": True,
        })
    elif not in_declared and kb_only:
        new_row.update({
            "status": kb_inferred["verdict"],
            "risk_level": kb_inferred["risk_level"],
            "verdict_basis": "knowledge_base_only",
            "kb_influenced": True,
        })
    elif not in_declared and in_technical:
        new_row["verdict_basis"] = "technical"
    adjusted.append(new_row)
```

kb_verdict_adjustments 处理过程

KB 判定伪代码（decision_rules.yaml）

```
- when: "declared and kb_supported"
  verdict: "kb_supported_consistent", risk_level: "low"
- when: "not_declared and kb_only"
  verdict: "kb_inferred_undeclared", risk_level: "high"
```

KB 支撑一致（由 declared_not_observed 升级，低风险）：政策已声明，技术 trace 弱或无，KB 或动态验证过程认为可行证据支持。

- 静态/动态/Frida 未覆盖，但权限、API 或 android_mapping 命中知识库。
- 避免将「证据链不完整」单独判为中风险；verdict_basis 记为 knowledge_base。

KB 推断未声明（高风险，仅 KB 观测）：政策未声明，且无技术 trace，仅有 KB 高置信推断。

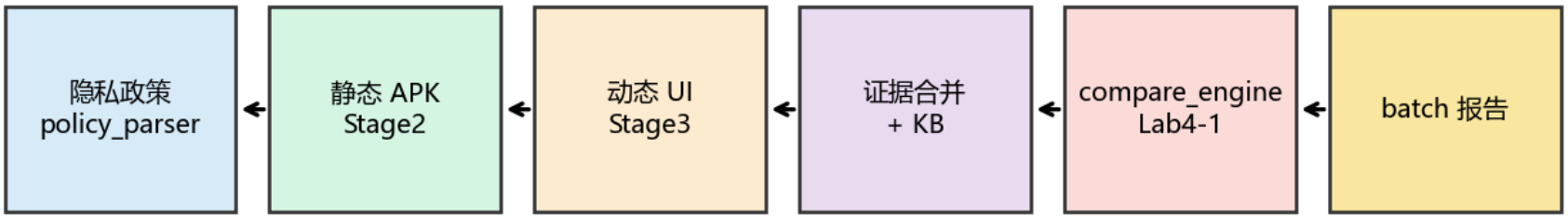
- 法律条目/别名推断会收集，但政策文本未写全。
- 与 inconsistent_high_risk 区分：后者通常有 static/dynamic 等技术证据；本类 verdict_basis 为 knowledge_base_only。

项目目录

项目目录

```
project/src/
  privacy_audit/      cli.py, evidence_loader.py
  privacy_knowledgebase/
  input/pii_text/     input/apk/
  output/stage2_static_samples/
  output/stage3_dynamic_real/
  output/lab4_1_evidence/    <- App.json 证据包
  output/lab4_1/             <- App_lab4_1_report.json
```

支撑 Lab4-1 的数据流



政策 → 静（Stage2）动（Stage3）证据验证 → `lab4_1_evidence/{App}.json` → `compare_engine` → batch 报告

政策匹配：先用子串匹配，后用分段聚类和 LLM 增强。

静态: Exodus / Androguard 抽取 SDK 权限和直接 API 命中。

动态: Appium / Frida 运行时使用 hooks 采集运行时证据，并进行别名匹配，包括 UI 测试和参数截图。

根据匹配的法律矩阵给出政策文件摘要和置信度，生成证据包。

使用大语言模型进行比较并生成最终 APP 报告，为降低幻觉使用 JSON 格式。

Lab04-1 核心模块

证据采集与合并

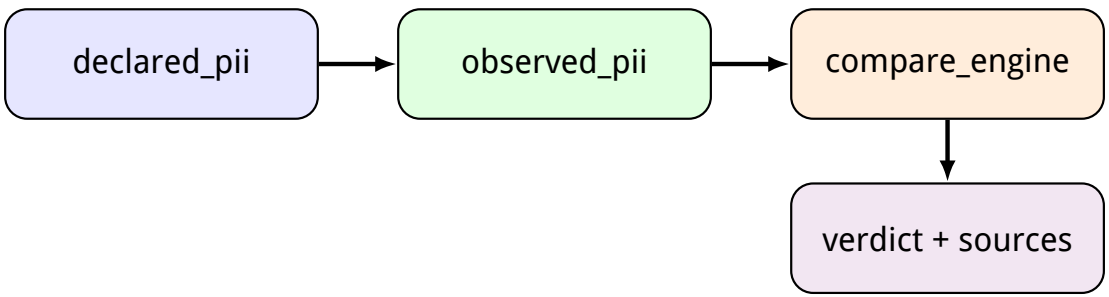
- policy_parser：从隐私政策文本匹配个人信息分类，得到 declared_pii。
- stage2_static：Exodus + Androguard 扫描 APK，生成 static_evidence.json。
- stage3_dynamic：Appium 导航 + Frida 采集，生成 dynamic_evidence.json。
- evidence_loader：合并静/动/oldsrc/legacy 等通道，写出 lab4_1_evidence/{App}.json。
- privacy_knowledgebase：法律矩阵与技术信号推断，补充 feasible_evidence 与观测类型。

审计与输出

- compare_engine：规则比对声明与观测，输出 consistent 等 verdict。
- lab4_1_report：汇总 verdicts、sources 与 KB 章节，导出单 App 报告 JSON。

判定逻辑示意

- `consistent`：政策声明的类型，在多源证据中可找到支撑。
- `inconsistent_high_risk`：证据链观测到某类型，但政策未充分声明（答辩重点）。
- `declared_not_observed`：政策声明了，但当前合并证据未观测到。



实验环境与样本

- **环境**：Windows + MuMu + Appium 4723 + Frida（Stage3 辅助，非 Lab4-1 唯一证据源）。
- **10 款 App**：Keep、小红书、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康、微信。
- **政策文本**：`input/pii_text/{App}.txt`
- **证据包**：`output/lab4_1_evidence/{App}.json`
- **报告**：`output/lab4_1/{App}_lab4_1_report.json`

Stage3 与 UI 适配（证据链一环）

- **世纪佳缘**：底部 Tab 文案为 " 我"（含空格）。" 推荐" 界面也存在多处" 我" 的入口。
- **小荷健康**：「设置」入口仅为齿轮图标且按钮 Label 为空，默认点击右上角最右侧元素（左侧多为扫一扫）。
- **支付宝**：存在「我的…」等入口，需精确匹配文案。
- **东方财富**：不存在" 我" 的入口，需要点击头像图标，且同时具有用户界面和个人主页。
- **其他 App**：政策路径 token + 精细化别名匹配 + 路径回退兜底。

Stage3 Corner Cases（真机截图）

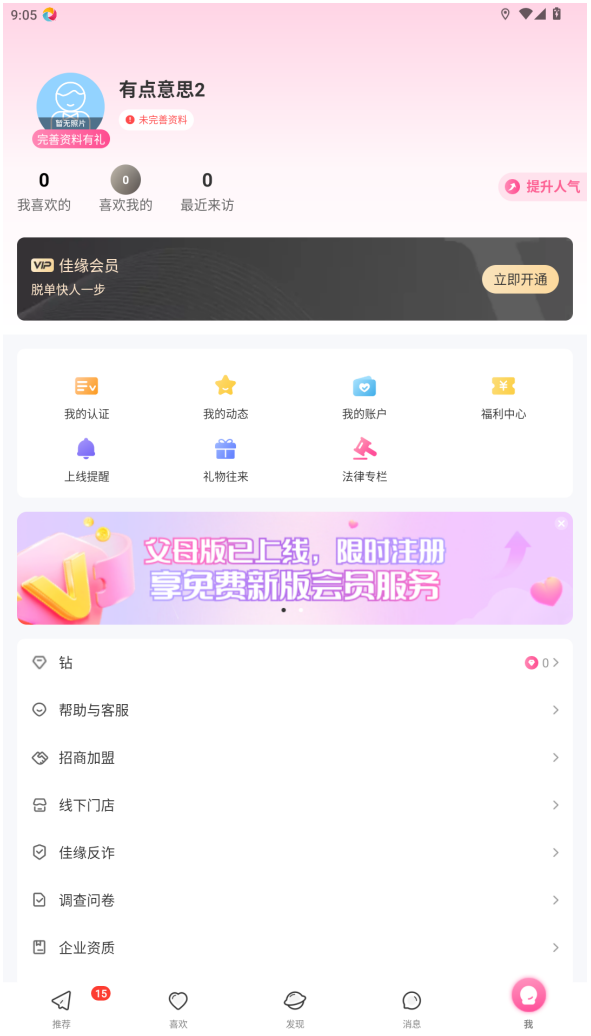
以下截图为 Lab04-1_CornorCases 目录中按 App 整理的 UI 适配难点；每页仅展示一款 App。

- **世纪佳缘**：底部 Tab 为 " 我"（含空格），推荐页亦有多处「我」入口。
- **东方财富**：无「我」文案入口，需点头像进入个人主页。
- **小荷健康**：「设置」为齿轮图标且 Label 为空，默认点右上角最右侧元素。

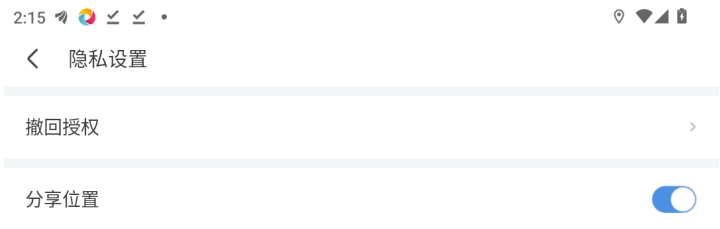
Corner Case：世纪佳缘

Tab 文案 " 我"（含空格）· 推荐页多处「我」· 路径 token 需精确匹配









Corner Case：东方财富

无「我」入口 → 点击头像图标进入个人主页



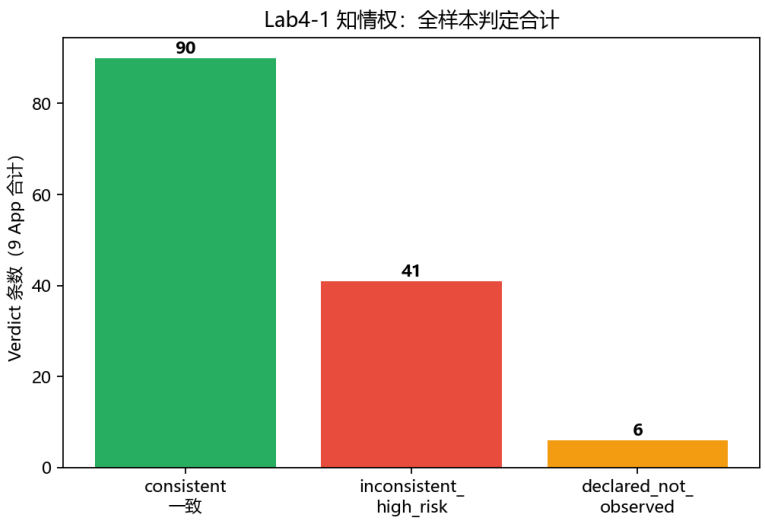


Corner Case：小荷健康

「设置」为齿轮图标、无障碍 Label 为空；默认点击右上角最右侧（左侧多为扫一扫）



全样本 Verdict 合计



Verdict	条数
consistent	90
inconsistent_high_risk	41
declared_not_observed	6

- 一致：声明有、证据也有
- 高风险：证据有、声明不足
- 未观测：声明有、证据暂无

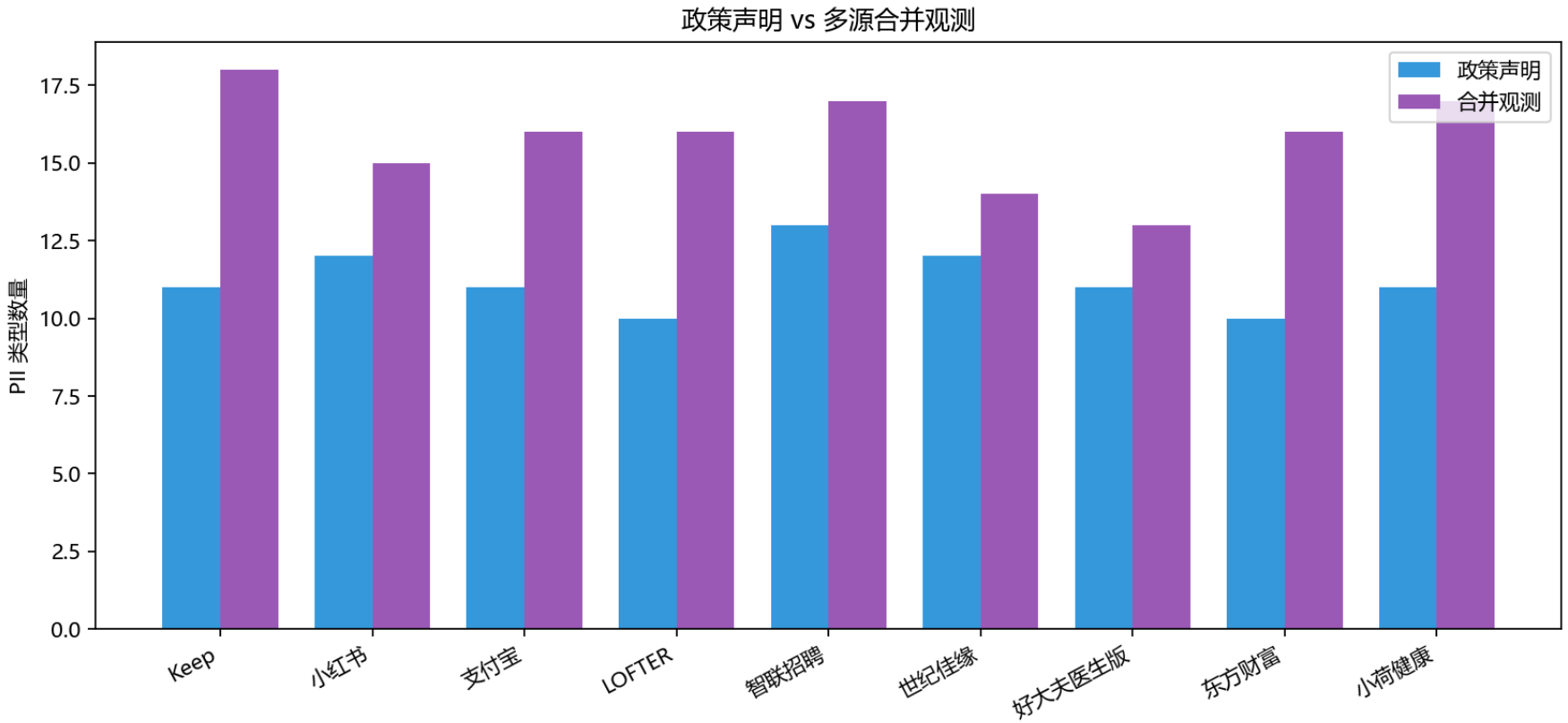
declared_not_observed 明细（6 条）

含义：政策 declared_pii 已声明，当前证据包 observed_pii_for_verdict 未命中；risk_level：medium。
批次：exp_stage3_20260525_lab4_1

1. **好大夫医生版**—account_info（账号信息）：受限于应用需要资格认证，无法动态验证。
2. **世纪佳缘**—biometric_info（生物识别）：静/动/oldsrc/KB 均未并入。
3. **东方财富**—log_info（日志信息）：声明有，观测列表无此项。
4. **世纪佳缘**—log_info（日志信息）：同上。
5. **支付宝**—clipboard（剪贴板）：政策已写，合并证据未列出。
6. **智联招聘**—clipboard（剪贴板）：同上。

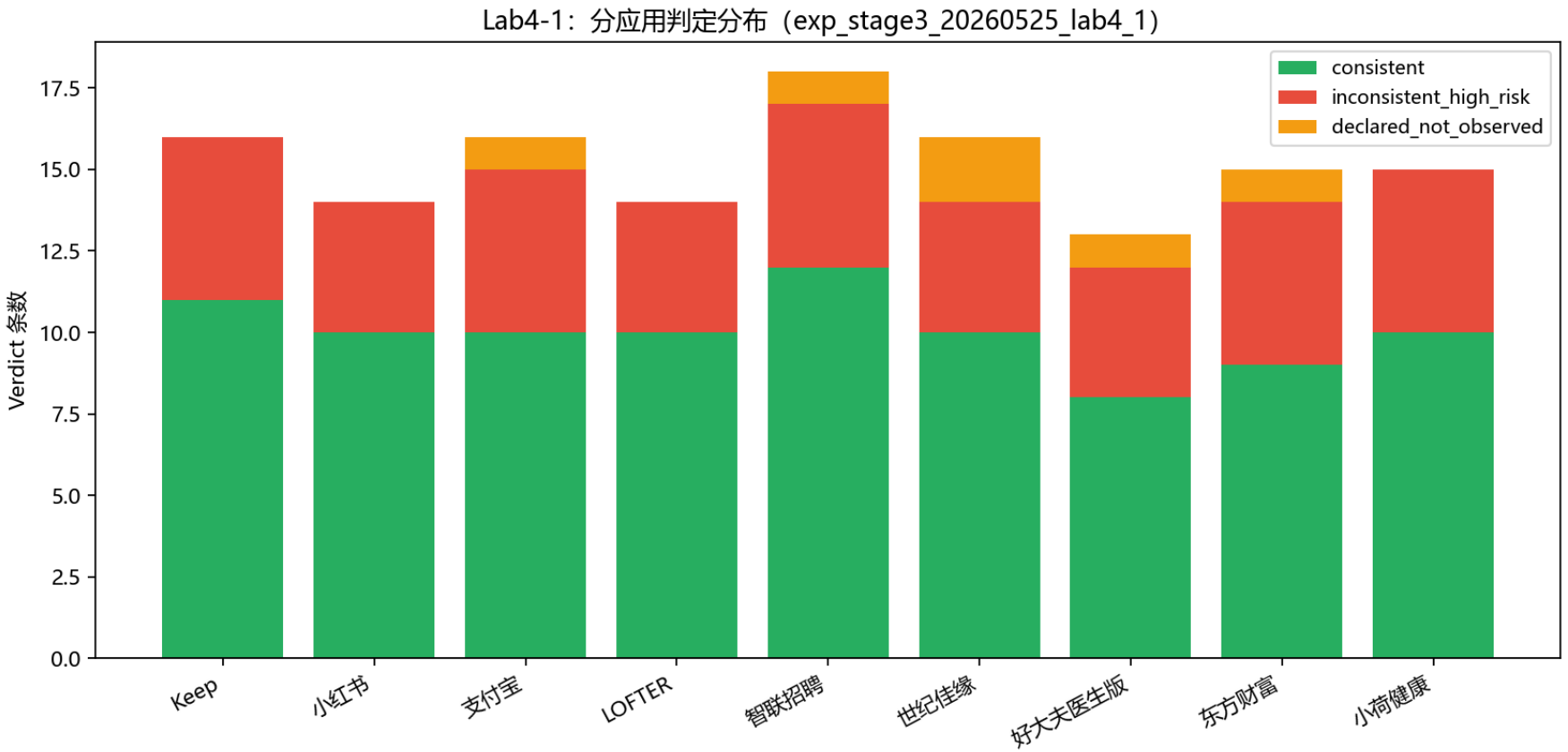
世纪佳缘原文："当您开通视频相亲、申请连麦、申请提现时……需要您提供真实身份信息（真实姓名、身份证件号码或人脸信息，根据实际情况可能有所不同）以完成实名认证。"但实际无法测试人脸信息部分。

政策声明 vs 合并观测（分 App）



多数 App 观测类型数 > 声明类型数 → 易出现 `inconsistent_high_risk`

分应用 Verdict 分布



分 App 数据表

App	声明	观测	一致	高风险	未观测	
Keep	11	18	11	5	0	
小红书	12	15	10	4	1	
支付宝	11	16	10	5	1	
LOFTER	10	16	10	4	2	
智联招聘	13	17	12	5	0	
世纪佳缘	12	14	10	4	2	
好大夫医生版	11	13	8	4	1	
东方财富	10	16	9	5	2	
小荷健康	11	17	10	5	0	

具体隐私内容（Keep）

声明（11）：账号, AndroidID, 身份, IMEI, IP, 位置, 日志, 未成年人, 权限, 手机号, 画像

观测（18）：账号, AndroidID, 生物识别, 剪贴板, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（5）：剪贴板, 通讯录, 权利, SDK, 安全

未观测（0）：无

具体隐私内容（小红书）

声明（12）：账号, AndroidID, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 未成年人, 权限, 手机号
观测（15）：账号, AndroidID, 生物识别, 通讯录, IMEI, IP, 位置, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全
高风险（4）：画像, 权利, SDK, 安全
未观测（0）：无

具体隐私内容（支付宝）

声明（11）：账号, AndroidID, 生物识别, 剪贴板, 通讯录, 身份, IMEI, IP, 位置, MAC, 手机号

观测（16）：账号, AndroidID, 生物识别, 通讯录, 身份, IMEI, IP, 位置, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（5）：未成年人, 权限, 权利, SDK, 安全

未观测（1）：剪贴板

具体隐私内容（LOFTER）

声明（10）： 账号, AndroidID, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号

观测（16）： 账号, AndroidID, 生物识别, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（4）： 通讯录, 权利, SDK, 安全

未观测（0）： 无

具体隐私内容（智联招聘）

声明（13）：账号, AndroidID, 生物识别, 剪贴板, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号

观测（17）：账号, AndroidID, 生物识别, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（5）：未成年人, 画像, 权利, SDK, 安全

未观测（1）：剪贴板

具体隐私内容（世纪佳缘）

声明（12）：账号, AndroidID, 生物识别, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号
观测（14）：账号, AndroidID, 通讯录, 身份, IMEI, IP, 位置, MAC, 权限, 手机号, 画像, 权利, SDK, 安全
高风险（4）：画像, 权利, SDK, 安全
未观测（2）：生物识别, 日志

具体隐私内容（好大夫医生版）

声明（11）：账号, AndroidID, 生物识别, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号
观测（13）：AndroidID, 生物识别, 通讯录, IMEI, IP, 位置, MAC, 未成年人, 权限, 手机号, 画像, 权利, 安全
高风险（4）：通讯录, 未成年人, 权利, 安全
未观测（1）：账号

具体隐私内容（东方财富）

声明（10）：账号, AndroidID, 身份, IMEI, IP, 位置, 日志, MAC, 权限, 手机号

观测（16）：账号, AndroidID, 生物识别, 通讯录, 身份, IMEI, IP, 位置, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（5）：未成年人, 画像, 权利, SDK, 安全

未观测（1）：日志

具体隐私内容（小荷健康）

声明（11）：账号, AndroidID, 身份, IMEI, IP, 位置, 日志, MAC, 未成年人, 权限, 手机号

观测（17）：账号, AndroidID, 生物识别, 剪贴板, 通讯录, 身份, IMEI, IP, 位置, MAC, 未成年人, 权限, 手机号, 画像, 权利, SDK, 安全

高风险（5）：剪贴板, 通讯录, 画像, 权利, 安全

未观测（0）：无

9 App 类型并集与交集

	并集（至少 1 款 App 出现）	**交集（9 款 App 均有）**
声明	账号, AndroidID, 生物识别, 剪贴板, 通讯录, 身份, IMEI, IP, 位置, 日志, MAC, 未成年人, 权限, 手机号, 画像（15 类）	账号, AndroidID, 身份, IMEI, IP, 位置, 手机号（7 类）
观测	上列 + 权利, SDK, 安全（18 类）	AndroidID, 通讯录, IMEI, IP, 位置, MAC, 权限, 手机号, 画像, 权利, 安全（11 类）
高风险	剪贴板, 通讯录, 未成年人, 权限, 画像, 权利, SDK, 安全（8 类）	权利, 安全（2 类）
未观测	账号, 生物识别, 剪贴板, 日志（4 类）	无

高风险 = `inconsistent_high_risk`；未观测 = `declared_not_observed`。

并集观测 18 类中，仅 Keep/小荷等在**声明**侧含剪贴板；9 款交集声明仅 7 类，反映政策表述差异。

阶段性结论

- 完成 **9 App Lab4-1 知情权**批量审计，工程流水线稳定（9/9）。
- 规则引擎产出结构化判定（一致 90 + 高风险 41 + 未观测 6），可溯源、可复核。
- 主要发现：**41 条高风险不一致**，反映「观测类型多于政策声明」的普遍模式。
- 汇报边界：已说明证据多源性与 Frida 运行时局限；Lab4-2/3 留作后续工作。

判定伦理与监管话语：「隐瞒采集」为何更重？

核心判断

「未声明但观测到」优先于「声明但未观测到」——在**监管执法叙事**中较普遍，但**不是**法条中的固定数学公式。

本系统 `inconsistent_high_risk` / `declared_not_observed` 的权重设计，对齐的是**执法与测评实践中的侧重点**，而非声称「法律只惩罚前者」。

中国近年 App 个人信息治理：高频执法主题

通报、专项整治与典型违法案例中，常见表述包括：

- **未告知、未明示**处理目的、方式、范围；
- **实际收集与告知不一致**、默认收集、强制索权；
- **SDK 违规**、后台自启动、**超范围收集**。

监管与公众直觉里，「**没告诉用户就采了**」往往比「**政策写了很多但本次测评没抓到**」更容易被定性为明确违法或高风险，也更容易进入通报名单。

告知通胀：另一类问题，但落地路径不同

「政策过宽、笼统、堆砌」（**告知通胀**）同样会被批评，涉嫌违反**明确、合理、必要**及误导用户。

- 处罚落地往往需结合：**是否真采集**、**最小必要**、**同意是否有效**；
- 自动化测评中 declared_not_observed ≠ 监管已认定「恶意夸大」，更多表示**待核查**或**测试局限**；
- 本系统 KB 对「声明但未观测」的放宽，体现的是**证据不足时克制判高风险**，而非认可笼统告知。

国际对照（GDPR）与本系统定位

- GDPR：**缺乏透明度**与**缺乏合法依据**均可严重违规；对外执法叙事中，*secret processing*（用户不知情的处理）冲击力通常大于冗长、模糊的隐私政策。
- 后者多走 **transparency + fairness** 路径，需结合实务评估，通常不会仅凭「本次未观测到」即定论。
- **本 Lab4-1**：规则 + 证据驱动的声明—观测对齐；更敏感于 `not_declared & observed`，对 `declared & not_observed` 在 KB 下保留复核空间——与当前主流**测评/执法权重**同向，但局限于声明膨胀、观测假阳性等。

市场阶段：规则已有，标准仍在细化

阶段特征	说明	是否符合
开放、监管缺位	PIPL、国标、App 备案、SDK 规定、专项整治、应用商店规则等已建立	基本**已过**
规范建立、健康发展（过渡）	类型划分与「告知—行为」对齐标准、自动化口径仍在演进；执法**有节奏、有重点**（先打未告知、超范围、SDK 等硬伤）	**最符合**
完全成熟、可机械打分	场景差异大；政策—代码无全国统一自动判据；「测不全」与「真未采」难区分	**尚不符合**

「更重隐瞒采集」是**过渡型市场**中常见的监管伦理：方向已明，执行上先抓危害感知强、证据较易认定的问题；对「写得太多/测不到」侧重**改进告知 + 抽查核实**，而非一律按「窃取」论处。

展望与后续工作

- **局限补强**：关注告知通胀（宽泛声明降低 not_declared 命中率）；区分 inconsistent_high_risk（技术）与 kb_inferred_undeclared（仅 KB）。
- **工程延伸**：Lab4-2 同意、Lab4-3 访问/更正/删除；可选增加「过度声明/模糊用语」指标，与知情权审计互补。
- **研究定位**：本系统宜定位为**过渡市场中的告知—行为对齐审计工具**，而非全面法律合规的终局评分器。

感谢聆听！

Q & A